Tiếng Việt (Vietnamese)	English (English)
THÔNG TIN ĐỀ TÀI / PROJECT INFORMATION	**THÔNG TIN ĐỀ TÀI / PROJECT INFORMATION**
Tên đề tài: Nghiên cứu và xây dựng hệ thống kiểm thử bảo mật Web/API có trạng thái, hỗ trợ bởi AI, cho lỗi phân quyền và logic nghiệp vụ trong môi trường được ủy quyền **CBHD:** TS. Nguyễn An Khương (Khoa KH&KT Máy tính, Trường ĐH Bách khoa - ĐHQG-HCM) **Sinh viên:** Đặng Huyền Vũ - 2313950; Trần Lê Đức An - 2310038; Phạm Xuân Bắc - 2310280 **Ngành/CTĐT:** Khoa học máy tính / định hướng AI và Cybersecurity **Kế hoạch:** Giai đoạn 1 - ĐACN HK261, 15 tuần; Giai đoạn 2 - ĐATN HK262, 15 tuần	**Project Title:** Research and Development of an AI-Assisted Stateful Web/API Security Testing System for Authorization and Business-Logic Flaws in Authorized Environments **Supervisor:** Dr. Nguyen An Khuong (Faculty of Computer Science and Engineering, HCMUT-VNU-HCM) **Students:** Dang Huyen Vu - 2313950; Tran Le Duc An - 2310038; Pham Xuan Bac - 2310280 **Major/Program:** Computer Science / AI and Cybersecurity orientation **Plan:** Phase 1 - Specialized Project, Semester 261, 15 weeks; Phase 2 - Graduation Thesis, Semester 262, 15 weeks
I. TÍNH CẤP THIẾT & KHOẢNG TRỐNG NGHIÊN CỨU	**I. MOTIVATION AND RESEARCH GAPS**
API hiện đại có nhiều vai trò, phiên đăng nhập, object ownership, tenant, trạng thái nghiệp vụ và workflow nhiều bước. Vì vậy, lỗi phân quyền không chỉ là một endpoint trả về 200 thay vì 403 mà nó còn thường chỉ lộ ra khi so sánh hành vi của nhiều actor trên cùng object hoặc cùng business state. OWASP API Security Top 10 2023 xem BOLA, BOPLA, BFLA và Unrestricted Access to Sensitive Business Flows là các rủi ro cốt lõi của API. Để đảm bảo tính khả thi và tập trung vào các mục tiêu nghiên cứu cụ thể, đề tài được xác định với phạm vi kỹ thuật rõ ràng. Trọng tâm là kiểm thử bảo mật trạng thái (Stateful) cho các lỗi phân quyền và lỗi logic nghiệp vụ. Các nội dung sau đây nằm ngoài phạm vi của đề tài: web reconnaissance, xây dựng attack-surface graph, kiểm chứng (PoC) cho các lỗi	Modern APIs involve roles, sessions, object ownership, tenants, business states, and multi-step workflows. Authorization flaws are therefore not simply endpoints returning 200 instead of 403; they often only surface when comparing the behaviors of multiple actors on the same object or within the same business state. The OWASP API Security Top 10 2023 identifies BOLA, BOPLA, BFLA, and Unrestricted Access to Sensitive Business Flows as core API risks. To ensure feasibility and focus on specific research objectives, the project is defined with a clear technical scope. The primary focus is on Stateful security testing for authorization and business logic flaws. The following areas are outside the scope of this project: Web reconnaissance, attack-surface graph construction, Proof-of-Concept (PoC) for common SQLi/XSS/Command injection flaws, SOC rule generation, malware/DFIR handling, and AI data-flow governance.

SQLi/XSS/Command injection phổ thông, xây dựng luật SOC, xử lý malware/DFIR, và quản trị luồng dữ liệu AI. Đề tài là sự tổng hòa của các chuyên môn bổ trợ, đảm bảo bao phủ toàn bộ vòng đời phát triển và đánh giá hệ thống trong lĩnh vực Offensive Security và Web Application Security, thông qua các công cụ như Burp Suite, PortSwigger và môi trường HackTheBox, cho phép tối ưu hóa việc phân tích mô hình đe dọa (threat model) và thiết lập các baseline thủ công chính xác. Song song đó, nội dung đề tài cũng bao gồm việc xây dựng và vận hành hệ thống gồm Full-stack Development, Compiler và quản trị hạ tầng mạng (như Docker, OPNsense, Wireshark), để có thể dựng Cyber Range và phát triển các thành phần orchestrator phức tạp. Cuối cùng, đề tài cũng cần ứng dụng Machine Learning, Python/SQL và kỹ thuật phân tích dữ liệu, để thiết lập các hệ systems ranking, đo lường metric cũng như thực hiện các ablation study để đánh giá kết quả một cách khoa học, khách quan. Sự đa dạng trong kỹ năng này giúp nhóm thực hiện đề tài có thể tự chủ hoàn toàn trong quá trình triển khai và tối ưu hóa hệ thống kiểm thử bảo mật. Đề tài cần tích hợp với các kết quả nghiên cứu hiện có trong lĩnh vực bằng cách tái sử dụng các dữ liệu đầu vào chuẩn (OpenAPI, HAR, inventory) từ các nghiên cứu về Web reconnaissance và học hỏi kỷ luật kiểm chứng từ hướng DAST. Điểm đóng góp khoa học riêng biệt của đề tài tập trung vào: mô hình role-session-object, xây dựng test-sequence có trạng thái, cơ chế authorization oracle/business-flow oracle và quy trình triage có sự tham gia của con người (Human-in-the-loop). **Phân tích Khoảng trống nghiên cứu chuyên sâu (In-depth Research Gaps):**	The project benefits from a synergy of complementary expertise, ensuring comprehensive coverage of the system development and evaluation lifecycle. Our team possesses a solid foundation in Offensive Security and Web Application Security, with hands-on experience using tools such as Burp Suite, PortSwigger, and the HackTheBox environment, enabling optimized threat modeling and the establishment of precise manual baselines. In parallel, the project involves system construction and operations, utilizing skills in Full-stack Development, Compiler design, and network infrastructure management (e.g., Docker, OPNsense, Wireshark) to build the Cyber Range and develop complex orchestrator components. Finally, the project applies Machine Learning, Python/SQL, and data analysis techniques to establish ranking systems, measure metrics, and conduct ablation studies to evaluate results scientifically and objectively. This diversity of skills enables the team to maintain full autonomy throughout the deployment and optimization of the security testing system. The project integrates with existing research in the field by reusing standard input data (OpenAPI, HAR, inventory) from Web reconnaissance studies and adopting verification discipline from DAST research. The project's distinct scientific contribution focuses on the role-session-object model, stateful test-sequence generation, authorization oracle/business-flow oracle mechanisms, and a Human-in-the-loop triage process. **In-depth Research Gap Analysis:** **Gap 1 (State-Space Explosion in Multi-actor Workflows):** The combinatorial explosion of state space and transition sequences when testing multi-role, multi-session, and multi-tenant workflows renders brute-force or naive random fuzzing computationally intractable. **Gap 2 (Semantic Inadequacy of Schema-based DAST & LLM Hallucination Risks):** State-of-the-art DAST tools (e.g., RESTler,

Gap 1 (State-Space Explosion in Multi-actor Workflows): Sự bùng nổ không gian tổ hợp trạng thái và chuỗi chuyển dịch khi kiểm thử kết hợp nhiều vai trò, nhiều phiên đăng nhập và nhiều ranh giới tenant khiến các phương pháp vét cạn hoặc fuzzing ngẫu nhiên không khả thi về chi phí và thời gian.

Gap 2 (Semantic Inadequacy of Schema-based DAST & LLM Hallucination Risks): Các công cụ DAST học thuật (RESTler, Schemathesis) suy luận phụ thuộc từ OpenAPI nhưng thiếu hoàn toàn ngữ cảnh về quyền sở hữu đối tượng và quan hệ đa vai trò; ngược lại, việc dùng LLM trực tiếp dễ dẫn đến ảo giác, sinh request ngoài phạm vi và thiếu kiểm soát an toàn nghiêm ngặt.

Gap 3 (Lack of Standardized Benchmarks with Verifiable Ground Truth): Thiếu các Cyber Range đa tenant có trạng thái được chuẩn hóa, có nhãn kiểm chứng (ground truth) để đánh giá khả năng phát hiện lỗi logic và phân quyền một cách định lượng (Precision, Recall, False Positive).

Hệ thống Câu hỏi nghiên cứu (Research Questions):

RQ1: Làm thế nào để tự động trích xuất và mô hình hóa quan hệ Role-Session-Object cùng máy trạng thái nghiệp vụ (Business State Graph) từ tài liệu OpenAPI và luồng traffic thực tế?

RQ2: Cơ chế lập kế hoạch kiểm thử hỗ trợ bởi AI (AI-assisted Planner/Ranker) kết hợp với các ràng buộc hình thức được thiết kế như thế nào để tối ưu hóa việc chọn chuỗi request có xác suất bộc lộ lỗi cao nhất dưới ngân sách hữu hạn?

RQ3: Các cơ chế Differential Authorization Oracle và State Invariant Oracle cần được thiết kế như thế nào để xác minh vi phạm phân quyền và luồng nghiệp vụ tự động, chính xác, không gây dương tính giả?

Schemathesis) infer dependencies purely from OpenAPI syntax, lacking semantic awareness of object ownership models; conversely, unconstrained LLM testing suffers from hallucinations, out-of-scope executions, and lack of deterministic safety guarantees.

Gap 3 (Lack of Standardized Benchmarks with Verifiable Ground Truth): The research community lacks standardized, stateful, multi-tenant Cyber Ranges equipped with verifiable ground-truth annotations for empirical benchmarking of stateful authorization and logic flaw detection.

Research Questions (RQs):

RQ1: How can Role-Session-Object topologies and Business State Graphs be automatically synthesized from OpenAPI specifications and passive traffic captures?

RQ2: How can an AI-assisted Planner/Ranker be formulated with formal constraints to prioritize request sequences that maximize flaw discovery probability under strict budgets?

RQ3: How should automated Differential Authorization and State Invariant Oracles be designed to reliably detect authorization breaches without noise?

RQ4: What is the quantitative impact of a Human-in-the-loop (HITL) triage framework on achieving high precision ($Precision \ge 0.85$) and minimizing verification overhead?

RQ4: Quy trình thẩm định có sự tham gia của con người (Human-in-the-loop Triage) đóng góp định lượng như thế nào vào việc nâng cao độ chính xác ($Precision \ge 0.85$) và giảm thời gian thẩm định thực tế so với quy trình thủ công?	
II. GIAI ĐOẠN 1: NỀN TẢNG KIỂM THỬ & CYBER RANGE (ĐACN HK261)	**II. PHASE 1: TESTING FOUNDATION & CYBER RANGE (SPECIALIZED PROJECT HK261)**
Giai đoạn này tạo nền tảng kiểm thử có thể tái lập: định nghĩa đúng lỗi authorization/business logic, dựng cyber range có nhiều role và state, chuẩn hóa bằng chứng HTTP, và xây baseline để GĐ2 không biến thành wrapper gọi LLM. **Nhiệm vụ cụ thể:** **1. Systematic Survey & Boundary Validation:** khảo sát OWASP API Security Top 10 2023, WSTG Authorization Testing, Authorization Testing Automation/Regression, NIST SP 800-115, RESTler, Schemathesis và lab app như crAPI/WebGoat/Juice Shop. Lập ma trận claim–evidence và ma trận không trùng lặp trong các các nghiên cứu liên quan. Chốt RQ, non-goals, threat model và các điều kiện dùng AI. **2. Authorization & Business-Logic Taxonomy:** định nghĩa 3-5 họ lỗi bắt buộc: BOLA/IDOR, BFLA, object-property authorization/mass assignment, tenant isolation breakage và workflow abuse có giới hạn. Mỗi họ lỗi có oracle, điều kiện tái lập, expected safe response, evidence cần thu và CWE/OWASP mapping. **3. Cyber Range as Code:** dựng 2-3 Web/API lab apps, gồm ít nhất một app chuẩn và một app tự dựng có OpenAPI spec, nhiều role, nhiều tenant, object ownership, trạng thái đơn hàng/ticket/tài liệu và workflow nhiều bước. Tất cả account, token và dữ liệu là synthetic; range có seed/reset cố định. **4. Role-Session-Object Model:** thiết kế mô hình Actor-Resource-Action-State gồm role, user, tenant, owner, relationship, session, token scope, endpoint, method,	This phase builds the reproducible testing foundation: define authorization/business-logic flaws, construct a multi-role and stateful cyber range, normalize HTTP evidence, and establish baselines so Phase 2 does not become an LLM wrapper. **Specific tasks:** **1. Systematic Survey & Boundary Validation:** survey OWASP API Security Top 10 2023, WSTG Authorization Testing, Authorization Testing Automation/Regression, NIST SP 800-115, RESTler, Schemathesis, and lab apps such as crAPI/WebGoat/Juice Shop. Build claim-evidence and non-overlap matrices against related works. Freeze RQs, non-goals, the threat model, and AI-use conditions. **2. Authorization & Business-Logic Taxonomy:** define 3-5 mandatory flaw families: BOLA/IDOR, BFLA, object-property authorization/mass assignment, tenant isolation breakage, and bounded workflow abuse. Each family includes an oracle, reproduction conditions, an expected safe response, evidence requirements, and a CWE/OWASP mapping. **3. Cyber Range as Code:** build 2-3 Web/API lab apps, including at least one standard app and one custom app with OpenAPI specification, multiple roles, tenants, object ownership, order/ticket/document states, and multi-step workflows. All accounts, tokens, and data are synthetic; the range supports fixed seeding and reset. **4. Role-Session-Object Model:** design an Actor-Resource-Action-State model covering role, user, tenant, owner, relationship, session, token scope, endpoint, method,

precondition và postcondition. Mô hình phải đọc được bằng YAML/JSON để con người review và máy sinh sequence. **5. Workflow Capture & Evidence Schema:** tự động trích xuất workflow từ traffic (HAR/OpenAPI), proxy traffic hoặc script thủ công; suy luận dependency, object-ID flow, transition và điểm hoán đổi actor/object. Chuẩn hóa request, response, status, diff, before-after state, test actor, seed, action ID, timestamp và raw hash; redact cookie/token/PII. **6. Safety Gateway & Baselines:** mọi test đi qua host/path/method allowlist, action allowlist, rate/concurrency budget, dry-run, kill switch, audit log, request cap và state reset. Baseline gồm manual/Burp checklist, role-matrix regression, random/state-unaware mutation và schema-based negative testing. **7. Phase 1 Evaluation:** đo workflow coverage, endpoint-operation coverage, role/object pair coverage, valid sequence rate, false positive trước/sau triage, request/time/token cost, reproducibility across seeds và failure cases. **Sản phẩm GĐ1:** gap matrix; boundary table; RQ/threat model/safety policy; cyber range; role-session-object schema; workflow/state extractor; evidence schema; safety gateway; replay harness; baselines; redacted logs; benchmark script; báo cáo ĐACN và demo.	precondition, and postcondition. The model must be readable as YAML/JSON for human review and machine sequence generation. **5. Workflow Capture & Evidence Schema:** collect valid requests from OpenAPI, proxy traffic, HAR, or manual scripts; infer dependencies, object-ID flows, transitions, and actor/object substitution points. Normalize requests, responses, statuses, diffs, before-after states, actors, seeds, action IDs, timestamps, and raw hashes; redact cookies/tokens/PII. **6. Safety Gateway & Baselines:** every test passes through host/path/method allowlists, an action allowlist, rate/concurrency budgets, dry run, kill switch, audit logs, request caps, and state reset. Baselines include manual/Burp checklist, role-matrix regression, random/state-unaware mutation, and schema-based negative testing. **7. Phase 1 Evaluation:** measure workflow coverage, endpoint-operation coverage, role/object-pair coverage, valid-sequence rate, false positives before/after triage, request/time/token cost, reproducibility across seeds, and failure cases. **Phase-1 deliverables:** gap matrix; boundary table; RQs/threat model/safety policy; cyber range; role-session-object schema; workflow/state extractor; evidence schema; safety gateway; replay harness; baselines; redacted logs; benchmark scripts; Specialized Project report; and demo.
III. GIAI ĐOẠN 2: AI-ASSISTED STATEFUL TESTING & HITL TRIAGE (ĐATN HK262)	**III. PHASE 2: AI-ASSISTED STATEFUL TESTING & HITL TRIAGE (GRADUATION THESIS HK262)**
Giai đoạn này phát triển planner/ranker hỗ trợ bởi AI để ưu tiên sequence có khả năng làm lộ lỗi authorization/business logic, nhưng vẫn giữ analyst trong vòng phê duyệt. Đóng góp chính là state model, sequence strategy, evidence tái lập và đánh giá đối chuẩn. **Nhiệm vụ cụ thể:**	This phase develops an AI-assisted planner/ranker that prioritizes sequences likely to expose authorization/business-logic flaws while keeping the analyst in the approval loop. The contribution is the state model, sequence strategy, reproducible evidence, and controlled evaluation. **Specific tasks:**

1. Formal Problem Formulation: tại trạng thái s_t, chọn sequence q_t để tối đa hóa số vi phạm hợp lệ dưới ràng buộc request budget, state reset cost, token cost, thời gian, coverage tối thiểu và safety policy. Báo cáo trade-off, không gom vào một điểm duy nhất.	**1. Formal Problem Formulation:** at state s_t, choose a sequence q_t to maximize valid violations under request budget, state-reset cost, token cost, time, minimum coverage, and safety-policy constraints. Report trade-offs instead of collapsing them into one score.
2. AI-Assisted Planner/Ranker: phát triển mô hình AI (LLM-based) kết hợp các ràng buộc dựa trên rule để lập kế hoạch sinh các sequence có mục tiêu dựa trên history và triage feedback. Input gồm OpenAPI/traffic, role-session-object model, state graph, finding history và triage feedback; output là sequence có mục tiêu, lý do chọn, precondition, budget và expected evidence.	**2. AI-Assisted Planner/Ranker:** combine rule-based constraints with an LLM or lightweight ranking model. Inputs include OpenAPI/traffic, the role-session-object model, state graph, finding history, and triage feedback; output is a targeted sequence with rationale, preconditions, budget, and expected evidence.
3. Constrained Tool Use / DSL Engine: AI chỉ thao tác trên DSL create/login/read/update/delete/replay/switch-actor/assert/reset; không có shell tự do, payload exploit tùy ý hoặc request ngoài allowlist. Prompt/context phải bám theo evidence object, không suy diễn từ tên endpoint.	**3. Constrained Tool Use / DSL Engine:** AI operates only on a DSL containing create/login/read/update/delete/replay/switch-actor/assert/reset; there is no free shell, arbitrary exploit payload, or out-of-allowlist request. Prompt/context must be grounded in evidence objects rather than endpoint names alone.
4. Human-in-the-Loop Triage: Vũ xác minh PoC an toàn, phân loại BOLA/BFLA/BOPLA/tenant/workflow, ghi expected vs observed, impact, exploitability trong lab và reason code. Finding chỉ được tính khi có script replay và bằng chứng trước-sau.	**4. Human-in-the-Loop Triage:** Vu validates safe PoCs, classifies BOLA/BFLA/BOPLA/tenant/workflow cases, and records expected versus observed behavior, impact, lab exploitability, and reason codes. A finding counts only with a replay script and before-and-after evidence.
5. Hardening & Benchmark: bổ sung rollback/reset, checkpoint/resume, idempotent cleanup, bounded queue, timeout/backoff, benign corpus và held-out scenarios. Tách development/test theo app hoặc scenario.	**5. Hardening & Benchmark:** add rollback/reset, checkpoint/resume, idempotent cleanup, bounded queues, timeout/backoff, a benign corpus, and held-out scenarios. Split development/test by app or scenario.
6. Baselines & Ablations: so sánh với manual/Burp checklist, role-matrix regression, random/state-unaware mutation và RESTler/Schemathesis-style baseline khi phù hợp. Ablate AI ranking, state model, ownership model, human feedback, evidence diff và stopping rule.	**6. Baselines & Ablations:** compare against manual/Burp checklist testing, role-matrix regression, random/state-unaware mutation, and RESTler/Schemathesis-style baselines when appropriate. Ablate AI ranking, the state model, ownership model, human feedback, evidence diff, and stopping rule.
	7. Repeated Evaluation: run at least 10 seeds/configurations for main experiments; report mean/median, SD/IQR, and bootstrap 95% CIs where appropriate. Metrics include valid finding

7. Repeated Evaluation: chạy tối thiểu 10 seed/configuration chính; báo cáo mean/median, SD/IQR và bootstrap 95% CI khi phù hợp. Metric gồm valid finding precision@budget, recall trên planted flaws, triage time, requests per valid finding, false positive rate, state reset failure và token/time cost. **8. Research Hypothesis:** trên các scenario lab held-out, planner hỗ trợ AI đạt ít nhất một điều kiện: tăng >=20% valid finding precision@request budget hoặc giảm >=25% thời gian triage/finding hợp lệ so với baseline tốt nhất. Đây là giả thuyết kiểm chứng, không phải kết quả giả định. **Sản phẩm GĐ2:** AI-assisted planner/ranker; stateful sequence engine; HITL triage workflow; hardened replay/reset harness; benign/held-out benchmark; baseline/ablation results; reproducibility package; dashboard/report tối thiểu; báo cáo ĐATN, demo video và paper draft nếu kết quả đủ mạnh.	precision@budget, recall on planted flaws, triage time, requests per valid finding, false-positive rate, state-reset failures, and token/time cost. **8. Research Hypothesis:** on held-out lab scenarios, the AI-assisted planner satisfies at least one condition: >=20% higher valid finding precision at the same request budget or >=25% lower triage time per valid finding than the best baseline. This is a testable hypothesis, not an assumed result. **Phase-2 deliverables:** AI-assisted planner/ranker; stateful sequence engine; HITL triage workflow; hardened replay/reset harness; benign and held-out benchmark; baseline and ablation results; reproducibility package; minimal dashboard/report; Graduation Thesis; demo video; and a paper draft if results are strong enough.
IV. CHỈ SỐ ĐÁNH GIÁ (KPIs)	**IV. KEY PERFORMANCE INDICATORS (KPIs)**
GĐ1 - bắt buộc: 100% request đi qua safety gateway; 0 request ngoài allowlist; có dry-run, kill switch và audit log. Range có 2-3 app, >=3 role, >=2 tenant, >=30 API operation/workflow step và >=20 planted authorization/business-logic cases có ground truth. >=95% test case có provenance/raw hash; workflow coverage >=70%; role/object pair coverage >=60%. Có tối thiểu 4 baseline và test cho parser, replay, redaction, safety gateway, reset. **GĐ2 - bắt buộc:** mỗi sequence của planner có objective, precondition, expected evidence, safety budget và reason code. Precision sau HITL triage >=0.85 trên held-out scenarios; recall báo cáo riêng theo từng họ lỗi. Kiểm chứng giả thuyết >=20% precision@budget hoặc >=25% triage-time improvement; nếu không đạt phải phân tích nguyên nhân. Tối	**Phase 1 - mandatory:** 100% of requests pass through the safety gateway; zero out-of-allowlist requests; dry run, kill switch, and audit logs exist. The range has 2-3 apps, >=3 roles, >=2 tenants, >=30 API operations/workflow steps, and >=20 planted authorization/business-logic cases with ground truth. >=95% of test cases have provenance/raw hashes; workflow coverage >=70%; role/object-pair coverage >=60%. At least 4 baselines and tests for parsers, replay, redaction, safety gateway, and reset are required. **Phase 2 - mandatory:** every planner sequence has an objective, precondition, expected evidence, safety budget, and reason code. Post-HITL precision >=0.85 on held-out scenarios; recall is reported by flaw family. Test the hypothesis of >=20% precision@budget or >=25% triage-time improvement; if unmet, analyze causes. Run at least 10 seeds/configurations, include ablations, and report cost.

thiểu 10 seed/configuration chính, có ablation và báo cáo cost.

Nguyên tắc nghiệm thu: không sửa ground truth hoặc metric sau khi xem kết quả test; KPI không đạt vẫn được chấp nhận nếu artifact tái lập, failure analysis và giới hạn khái quát hóa rõ ràng.

Bảng KPI Chi tiết:

Metric	Target	Measurement Method
Workflow Coverage	>= 70%	Tỷ lệ API operations được kích hoạt hợp lệ trong Cyber Range.
Role-Object Pair Coverage	>= 60%	Tỷ lệ cặp vai trò và đối tượng được kiểm thử phân quyền chéo.
Post-Triage Precision	>= 0.85	Tỷ lệ vi phạm hợp lệ được chuyên viên xác nhận trên tổng số cảnh báo.
Triage Efficiency Gain	>= 25%	Tỷ lệ giảm thời gian thẩ định trên mỗi lỗi hợp lệ s với manual baseline.
Precision@Budget Gain	>= 20%	Tỷ lệ tăng precision tại cùng mức ngân sách request so với baseline tốt nhất.
Safety Gate Violations	= 0	Số lượng request vi phạ allowlist hoặc gây lỗi range không thể phục hồ

Acceptance principle: do not change ground truth or metrics after viewing test results; missed KPIs can still pass if artifacts are reproducible and failure analysis and generalization limits are explicit.

Detailed KPI Table:

Metric	Target	Measurement Method
Workflow Coverage	>= 70%	Ratio of exercised valid API workflow operations in Cyber Range.
Role-Object Pair Coverage	>= 60%	Ratio of cross-tested role and object pairs.
Post-Triage Precision	>= 0.85	Ratio of human-verified valid vulnerabilities over total reported candidates.
Triage Efficiency Gain	>= 25%	Reduction in analyst triage duration per verified flaw vs manual baseline.
Precision@Budget Gain	>= 20%	Precision increase at identical request budgets vs strongest baseline.
Safety Gate Violations	= 0	Total out-of-scope requests or unrecoverable range crashes.

V. LỘ TRÌNH & KẾ HOẠCH (ROADMAP)	V. ROADMAP & ACTION PLAN
Giai đoạn 1: ĐACN HK261 (09/2026 - 01/2027) (Tổng thời gian: 15 tuần)	**Phase 1: Specialized Project HK261 (09/2026 - 01/2027) (Total duration: 15 weeks)**
• T09/2026 (W1-W3): Khảo sát, định nghĩa RQ, taxonomy, xây dựng Threat/Safety model.	• 09/2026 (W1-W3): Survey, RQs, taxonomy, threat/safety model design.
• T10/2026 (W4-W6): Dựng Cyber Range, thiết lập roles/tenants, state machine & seed/reset.	• 10/2026 (W4-W6): Cyber Range construction, roles/tenants, state machine & seed/reset.
• T10-T11/2026 (W7-W9): Thu thập Workflow (OpenAPI/HAR), thiết lập Evidence schema & Replay harness.	• 10-11/2026 (W7-W9): Workflow collection, evidence schema & replay harness development.
• T11/2026 (W10-W11): Xây dựng Measurement harness, data store & benchmark scripts.	• 11/2026 (W10-W11): Measurement harness, data store & benchmark scripting.
• T12/2026 (W12-W13): Triển khai Baseline (Manual/Burp), role-matrix regression & negative tests.	• 12/2026 (W12-W13): Baseline deployment (Manual/Burp), role-matrix regression & negative tests.
• T12/2026-01/2027 (W14-W15): Freeze range/dataset, báo cáo & Demo.	• 12/2026-01/2027 (W14-W15): Freeze range/dataset, report & demo.
Phân công vai trò (Assignments):	**Role Distribution:**
- Vũ: threat model, manual baseline và kiểm chứng bằng chứng HTTP.	- Vu: threat model, manual baseline, and HTTP evidence verification.
- Đức An: state machine, orchestrator, cyber range và safety gateway.	- Duc An: state machine, orchestrator, cyber range, and safety gateway.
- Xuân Bắc: dữ liệu, ranking, metric, ablation và phân tích kết quả.	- Xuan Bac: data, ranking model, metrics, ablation studies, and result analysis.
Giai đoạn 2: ĐATN HK262 (02/2027 - 06/2027) (Tổng thời gian: 15 tuần)	**Phase 2: Graduation Thesis HK262 (02/2027 - 06/2027) (Total duration: 15 weeks)**
• T02/2027 (W1-W3): Formal problem definition, thiết kế DSL & protocol.	• 02/2027 (W1-W3): Formal problem definition, DSL & protocol design.
• T03/2027 (W4-W6): Phát triển Planner/Ranker, prompt grounding & reason codes.	• 03/2027 (W4-W6): Planner/Ranker development, prompt grounding & reason codes.
	• 03-04/2027 (W7-W9): HITL triage, replay script development & evidence reporting.

• T03-T04/2027 (W7-W9): HITL triage, xây dựng script replay & evidence report. • T04/2027 (W10-W11): Hardening replay/reset, audit log & redaction. • T05/2027 (W12-W13): Ablation study, repeated experiments & thống kê kết quả. • T06/2027 (W14-W15): Finalize code/thesis, Demo & Bảo vệ. **CÁC MỐC QUAN TRỌNG (MILESTONES):** - M1: Chốt Boundary/RQ (09/2026); - M2: Duyệt Cyber Range (10/2026); - M3: MVP Replay/Evidence (11/2026); - M4: Hoàn thành GĐ1 (01/2027); - M5: Chốt Planner (03/2027); - M6: Chốt thực nghiệm (05/2027); - M7: Nghiệm thu cuối cùng (06/2027).	• 04/2027 (W10-W11): Hardening replay/reset, audit log & redaction. • 05/2027 (W12-W13): Ablation study, repeated experiments & statistical analysis. • 06/2027 (W14-W15): Finalize code/thesis, Demo & Defense. **MILESTONES:** - M1: Boundary/RQ freeze (09/2026); - M2: Cyber Range review (10/2026); - M3: Replay/Evidence MVP (11/2026); - M4: Phase-1 acceptance (01/2027); - M5: Planner freeze (03/2027); - M6: Experiment freeze (05/2027); - M7: Final acceptance (06/2027).
VI. RỦI RO & PHƯƠNG ÁN DỰ PHÒNG	**VI. RISK AND MITIGATION**
1. AI Hallucination & Token Exhaustion: Lập kế hoạch dựa trên ontology Role-Session-Object; trần ngân sách token cứng và ngắt mạch tự động. **2. Cyber Range State Drift & Reset Failure:** Docker containerization; khôi phục database snapshot nguyên tử trước mỗi sequence; kiểm tra sanity dry-run. **3. Tool Calling Safety & Out-of-Scope Requests:** Cấm shell tự do; ánh xạ hành vi qua DSL giới hạn; Safety Gateway kiểm tra allowlist URI/Method nghiêm ngặt. **4. Benchmark Contamination & Overfitting:** Phân tách kịch bản Development và Held-out Benchmark; đo độ lệch chuẩn trên >=10 seeds.	**1. AI Hallucination & Token Exhaustion:** Ontological grounding with the Role-Session-Object model; hard token budgets and circuit breaking. **2. Cyber Range State Drift & Reset Failure:** Docker containerization; atomic database snapshot restoration before each sequence; dry-run sanity checks. **3. Tool Calling Safety & Out-of-Scope Requests:** Prohibit free shell access; map actions through a restricted DSL; Safety Gateway enforces strict URI/Method allowlists. **4. Benchmark Contamination & Overfitting:** Strict separation of Development and Held-out Benchmark scenarios; measure standard deviation across >=10 seeds.
VII. TÀI LIỆU THAM KHẢO	**VII. REFERENCES**

[1] OWASP Foundation, OWASP API Security Top 10 - 2023. **[2] OWASP Foundation,** Web Security Testing Guide - Authorization Testing. **[3] NIST SP 800-115,** Technical Guide to Information Security Testing. **[4] V. Atlidakis et al.,** RESTler: Stateful REST API Fuzzing, ICSE 2019. **[5] Schemathesis,** Property-based testing for API schemas. **[6] QuickREST,** Property-based testing of RESTful APIs, ICST. **[7] RestFuzz,** Fuzzing RESTful APIs for security vulnerabilities, ASE. **[8] IEEE S&P & USENIX Security,** Selected papers on Web/API security (2020-2023). **[9] ACM CCS,** Conference on Computer and Communications Security.	**[1] OWASP Foundation,** OWASP API Security Top 10 - 2023. **[2] OWASP Foundation,** Web Security Testing Guide - Authorization Testing. **[3] NIST SP 800-115,** Technical Guide to Information Security Testing. **[4] V. Atlidakis et al.,** RESTler: Stateful REST API Fuzzing, ICSE 2019. **[5] Schemathesis,** Property-based testing for API schemas. **[6] QuickREST,** Property-based testing of RESTful APIs, ICST. **[7] RestFuzz,** Fuzzing RESTful APIs for security vulnerabilities, ASE. **[8] IEEE S&P & USENIX Security,** Selected papers on Web/API security (2020-2023). **[9] ACM CCS,** Conference on Computer and Communications Security.